Security Requirements Specification — Bank Management System

1. Introduction and Objectives

1.1 Purpose

This document specifies the security requirements, controls, and acceptance criteria for the Bank Management System. It establishes the security baseline required to protect customer funds, authentication credentials, and sensitive banking records against cyber threats and unauthorized access.

1.2 Security Objectives

1. Confidentiality: Prevent unauthorized disclosure of customer personal information, account balances, credentials, and transaction histories.

2. Integrity: Ensure that financial balances, ledger records, audit logs, and database snapshots cannot be modified, corrupted, or tampered with by unauthorized parties or partial execution failures.

3. Availability: Maintain system responsiveness and operational readiness under load, ensuring safe recovery from database lockouts or component failures.

4. Non-Repudiation and Accountability: Record an immutable, chronologically ordered audit trail of all sensitive authentication, financial, and administrative operations.

1.3 Scope and Threat Model

The system protects against common web application attack vectors including:

Credential stuffing and brute-force attacks

Cross-Site Request Forgery (CSRF)

Broken Object Level Authorization (Horizontal Privilege Escalation)

Vertical Privilege Escalation (Role Bypasses)

SQL Injection and Parameter Tampering

CSV / Spreadsheet Formula Injection

Clickjacking and MIME-type Sniffing

Database Backup Tampering and Restoration Corruption

1.4 Stakeholders and Actors

Customer: End-user accessing personal accounts, transfers, and loans.

Bank Employee: Authorized internal staff reviewing accounts and processing loan queues.

System Administrator: Privileged administrator overseeing audit trails, health diagnostics, and database disaster recovery.

2. Security Requirements Table

Security ID	Category	Security Requirement / Description	Priority	Acceptance Criteria	Rationale
---	---	---	---	---	---
SEC-01	Authentication	Session-Based Authentication: Users must authenticate with valid credentials before accessing protected resources. The system issues cryptographically signed HttpOnly, SameSite cookies.	High	Pass: Valid login creates a signed session; invalid credentials are rejected; sessions are immediately invalidated upon logout. Fail: Protected routes are accessible without a session, or session cookies lack HttpOnly flags.	Prevents unauthorized users and automated scripts from accessing banking functions.
SEC-02	Credential Protection	Cryptographic Password Hashing: User passwords must never be stored, transmitted, or logged in plain text. Passwords must be hashed using bcrypt	High	Pass: Database stores only salted bcrypt hashes with cost factor 12. Fail: Plain-text passwords appear in database	Protects user credentials against credential harvesting if database storage is compromised.

Security ID	Category	Security Requirement / Description	Priority	Acceptance Criteria	Rationale
		with random per-user cryptographic salts.		tables, log files, or API responses.	
SEC-03	Threat Mitigation	Brute-Force Rate Limiting: The system must enforce automatic lockout controls on repeated authentication failures to mitigate automated credential guessing.	High	Pass: 5 consecutive failed login attempts trigger a 15-minute account lockout; subsequent attempts within the lockout window are rejected with clear status. Fail: Unlimited login attempts are permitted without throttling.	Mitigates automated dictionary attacks and credential stuffing campaigns against user accounts.
SEC-04	Session Defense	Cross-Site Request Forgery Defense: All mutating HTTP requests (POST, PUT, DELETE) must validate a secure per-session anti-CSRF token supplied via the X-CSRF-Token header.	High	Pass: State-changing requests succeed only with a valid CSRF token; missing or forged tokens return HTTP 403 Forbidden. Fail: Mutating requests succeed without CSRF token validation.	Prevents malicious external websites from executing unauthorized banking actions on behalf of authenticated users.
SEC-05	Access Control	Role-Based Access Control: Server-side guards must enforce strict role boundaries restricting Customer, Employee, and Admin operations.	High	Pass: Each role accesses only permitted functions; Customer cannot access Employee queue or Admin backup; Employee cannot access Admin backup or audit logs. Fail: Privileged endpoints can be invoked by lower-privileged roles.	Prevents vertical privilege escalation and limits administrative powers to verified administrators.
SEC-06	Access Control	Horizontal Ownership Isolation: The system must verify that the authenticated user owns the requested account, beneficiary, loan, or profile record before reading or modifying data.	High	Pass: Requests for records belonging to another customer return HTTP 403 Forbidden or 404 Not Found. Fail: A customer can read balances, view histories, or execute transfers on another customer account.	Protects customer privacy and prevents horizontal data leaks between different bank customers.
SEC-07	Input Validation	Input Sanitization and SQL Injection Defense: All API inputs must be validated on the server for positive values, expected patterns, and bound via parameterized SQL queries.	High	Pass: Negative amounts, zero amounts, malformed account strings, and SQL injection payloads are rejected safely; queries execute via SQLite parameter bindings. Fail: Malicious SQL fragments alter query execution or change unauthorized data.	Prevents SQL injection and prevents corrupt or negative values from entering the banking ledger.
SEC-08	Financial Integrity	Atomic Processing and Rollback: All financial operations affecting multiple accounts must execute within an isolated ACID database transaction.	High	Pass: Both sender debit and recipient credit commit together, or both roll back on any mid-operation failure. Fail: A failed transfer leaves money debited from sender without reaching recipient.	Prevents partial transfers, race conditions, and ledger discrepancies during system faults.
SEC-09	Financial Integrity	Currency Precision and Overdraft Enforcement: Balances and transaction amounts must be handled using integer paise to prevent precision loss, and withdrawals must enforce available balance limits.	High	Pass: All balances use integer paise (1 INR = 100 paise); overdraft withdrawals are rejected with HTTP 400 Insufficient funds. Fail: Floating-point rounding discrepancies occur, or an account balance	Eliminates floating-point rounding errors and protects bank solvency by preventing unauthorized overdrafts.

Security ID	Category	Security Requirement / Description	Priority	Acceptance Criteria	Rationale
				drops below zero without credit authorization.	
SEC-10	Network Security	Defense-in-Depth HTTP Response Headers: All HTTP responses must include strict security headers and browser caching instructions for sensitive banking data.	Medium	Pass: Responses include Content-Security-Policy, X-Frame-Options: DENY, X-Content-Type-Options: nosniff, and Cache-Control: no-store, no-cache. Fail: Security headers are omitted or sensitive data is cached by public proxy servers.	Mitigates clickjacking, cross-site scripting (XSS), MIME-type sniffing, and sensitive data leakage via shared browser caches.
SEC-11	Client Protection	Spreadsheet Formula Injection Prevention: Tabular CSV statement exports must sanitize all cells beginning with formula trigger characters (=, +, -, @).	Medium	Pass: Exported CSV cells starting with formula characters are prepended with an apostrophe to neutralize execution in Excel or Calc. Fail: Raw formulas execute commands or leak data when customer opens exported statement in spreadsheet software.	Neutralizes CSV injection vulnerabilities where malicious account descriptions or notes trigger local command execution.
SEC-12	Accountability	Immutable Audit Trail Logging: Security-relevant events (authentication, access violations, account creation, fund transfers, loan decisions, and administrative actions) must be recorded in an immutable audit log.	High	Pass: Audit log records actor ID, role, action, target entity, client IP address, and UTC timestamp; records cannot be updated or deleted through the application. Fail: Sensitive actions occur without logging, or audit records can be modified by users.	Provides non-repudiation, forensics capability, and regulatory compliance verification.
SEC-13	Data Protection	Database Snapshot Cryptographic Verification: Online SQLite database backups must be verified using SHA-256 cryptographic hashes and internal consistency checks.	Medium	Pass: Created backups compute and store SHA-256 checksums; backup integrity verification executes PRAGMA integrity check and validates matching hashes. Fail: Corrupted, truncated, or tampered backup files are reported as valid.	Ensures backup archives remain authentic and usable before disaster recovery restoration is attempted.
SEC-14	Data Protection	Disaster Recovery with Pre-Restore Snapshot: Database restoration must create a safety checkpoint of the live database prior to applying a verified backup snapshot.	Medium	Pass: Pre-restore safety snapshot is created automatically; restore applies only verified backups; aborted restorations leave live database intact. Fail: Database restore corrupts live database or overwrites data without safety fallback.	Mitigates permanent data loss during administrative maintenance and recovery operations.
SEC-15	Availability	Database Lock Handling and Fault Isolation: The system must configure SQLite busy timeout handlers and enforce connection teardown rollbacks on unhandled errors.	Medium	Pass: Concurrent requests wait up to busy timeout without crashing; failed requests trigger automated connection rollback; service health check reports database liveness. Fail: Concurrent requests trigger locked database exceptions that crash the API process.	Ensures service availability and prevents persistent database locks from degrading banking operations.

3. Verification and Testing Traceability

Each security requirement is validated by automated test suites in backend/tests/:

Security ID	Mapped Automated Test Cases	Verification Method
---	---	---
SEC-01	test-login-success-and-session-persistence, test-logout, test-profile-requires-authentication	Automated Pytest
SEC-02	test-issue-19-no-plaintext-passwords-in-db-or-api, test-customer-registration-weak-password	Automated Database Inspection
SEC-03	test-login-brute-force-lockout	Automated Pytest (5 failed attempts)
SEC-04	test-csrf-protection-on-mutating-endpoints, test-profile-validation-and-csrf	Automated HTTP Header Inspection
SEC-05	test-rbac-admin-endpoint-forbidden-for-customer, test-rbac-employee-can-access-any-customer-account	Automated Role Testing
SEC-06	test-rbac-ownership-isolation-between-customers, test-other-customers-history-is-forbidden, test-user-cannot-change-another-users-profile	Automated Horizontal Privacy Testing
SEC-07	test-deposit-invalid-negative-or-zero-amount, test-transfer-validation-errors	Automated Boundary Testing
SEC-08	test-atomic-transfer-rollback-on-mid-transaction-failure, test-transfer-insufficient-funds-rejected-and-atomic	Automated Fault Injection Testing
SEC-09	test-withdraw-exceeding-balance-rejected, test-deposit-valid-amount-updates-balance	Automated Currency Precision Testing
SEC-10	test-issue-19-security-headers-and-cache-control	Automated Response Header Inspection
SEC-11	test-csv-export-escapes-spreadsheet-formula-injection	Automated CSV Content Parsing
SEC-12	test-audit-log-entries-created, test-issue-22-audit-logs-rbac-and-comprehensive-event-recording	Automated Audit Log Verification
SEC-13	test-admin-create-backup-success, test-verify-backup-integrity	Automated Cryptographic Hash Checking
SEC-14	test-end-to-end-disaster-recovery-restoration, test-restore-rejects-corrupted-backup	Automated Disaster Recovery Simulation
SEC-15	test-health-check, test-issue-21-teardown-rollback-and-fault_isolation	Automated Load and Health Checking